GOMACTech-2026

SLIDES ONLY
NO SCRIPT PROVIDED

CLEARED
For Open Publication
Mar 04, 2026
2
Department of Defense
OFFICE OF PREPUBLICATION AND SECURITY REVIEW

Enabling Comprehensive CWE-based Assurance for RISC-V Processors

March 11th, 2026

Jason Oberg, Fellow, Security Solutions
Arteris, Inc.

Amazing co-authors and partners

Will Cummings,
Jagadish Nayak, Mark Labbato
Cycuity, Inc. (Arteris, Inc.)

Gayatri Perlin, Joseph Lin, Richard Ferguson,
Steve Kim, Seung Moon
BAE Systems, Inc.

Mark Le, Trevor McKay
SiFive, Inc.

ARTERIS IP
BAE SYSTEMS
SiFive

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

Cycuity now part of Arteris

- Cycuity, Inc. was acquired by Arteris, Inc. in January 2026

- Arteris provides products for network on chip (NoC), cache IP, and system integration automation tools for modern SoC design and assembly

- The Cycuity team continues to focus on hardware security as an Arteris subsidiary called Arteris Security

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

RISC-V Security Assurance

How many unique RISC-V based designs exist today?

📍 **In Summary**

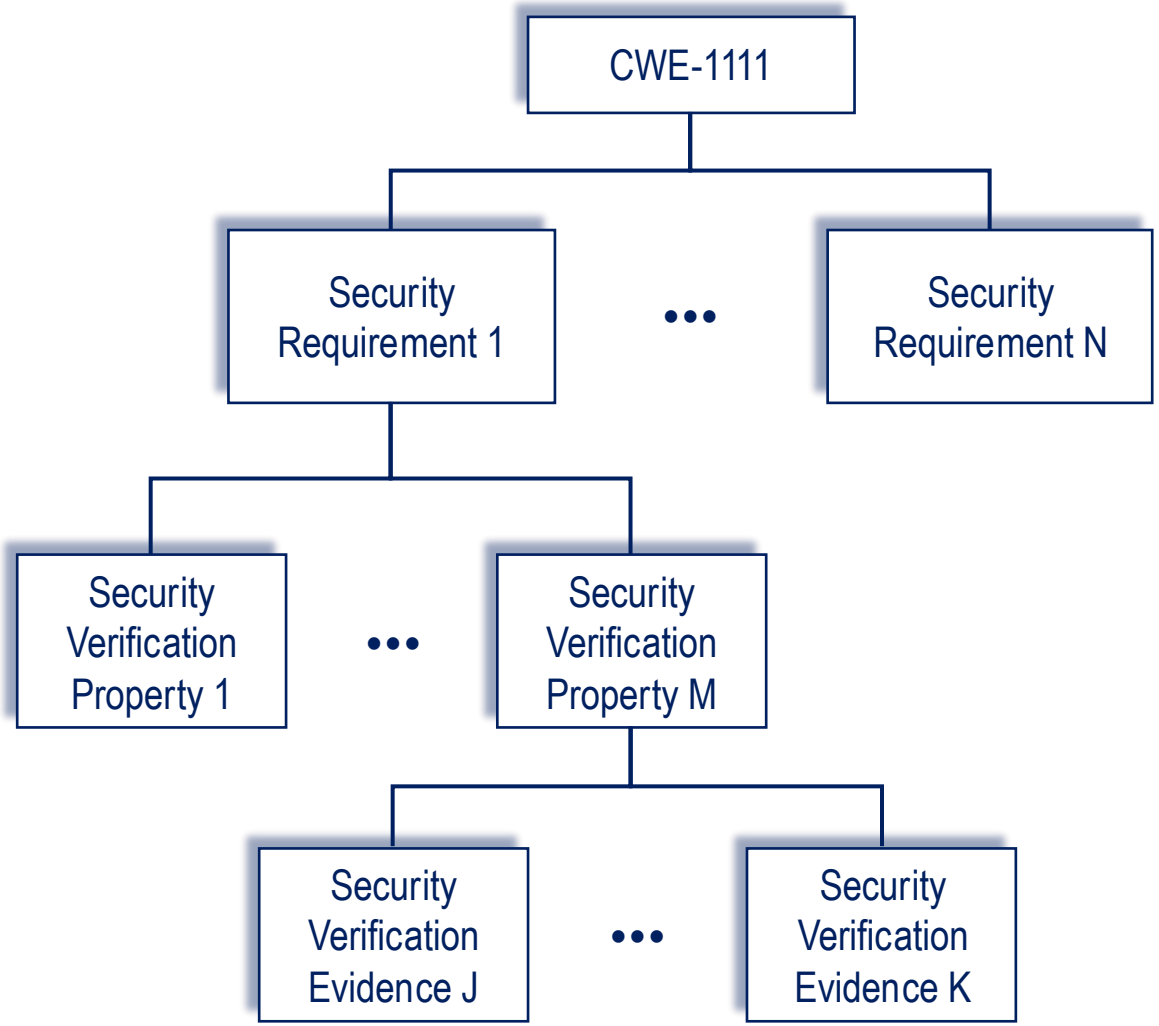
- **Publicly documented unique RISC-V designs:** at least ~70 distinct processor implementations currently listed in authoritative ecosystem trackers. Embedded Comp...
- **Total unique designs in existence (open-source + commercial + private):** *hundreds* — including variants, custom research designs, and proprietary cores. GitHub
- **Total cores shipped in products globally:** *billions* of instances of these various implementations. RISC-V Internatio...

- The RISC-V Instruction Set Architecture (ISA) is open but hundreds (thousands?) of custom implementations exist
- Security weaknesses are often caused by mistakes in design implementation or making intentional deviations for the ISA specification
- With a fragmented, open ecosystem both commercial and government organizations are missing a systematic methodology to assess security assurance for RISC-V design implementations
- Today we present the results of a proposed methodology based on the Common Weakness Enumeration (CWE)

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

Recap from GOMAC 2025: Proposed Microelectronics Evidence Tree

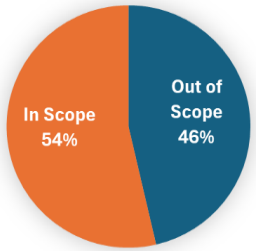
- The Microelectronics evidence tree is based on the Common Weakness Enumeration (CWE)
- Each node of the tree provides support evidence for its parent in the following relationship: ***CWEs → Security Requirements → Security Properties → Security Verification Evidence***
- All assurance is supported by *Security Verification Evidence* at the leaves of the tree.
- Methodology and initial concept presented last year at GOMAC 2025.



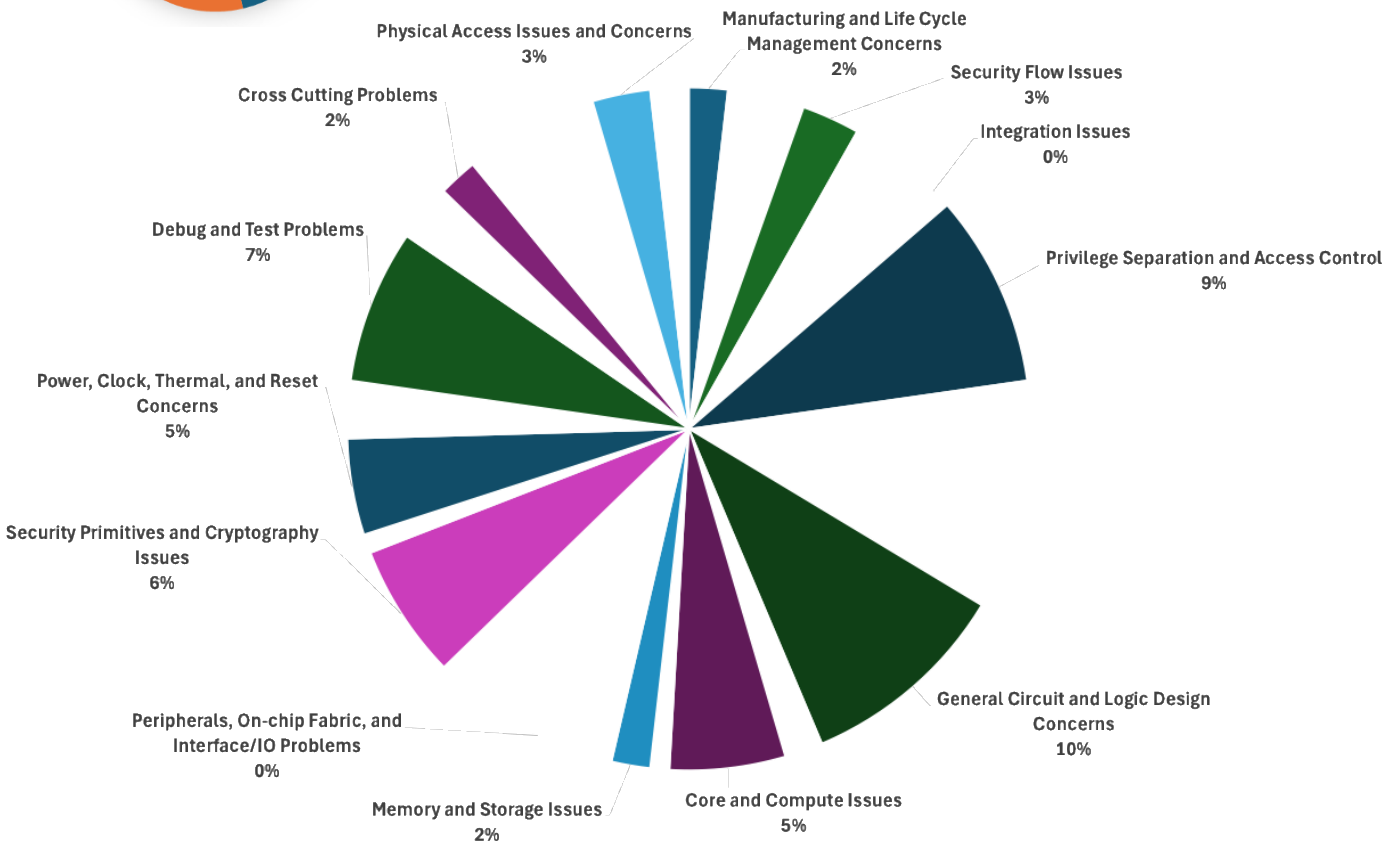
DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

CWE Applicability to SiFive's RISC-V X280 IP

Total CWEs in Scope (59)



CWE Scope by Category



- CWE scoping is a required first step
- Based on the top-level assessment of the library of CWEs, **54%** (59/110) were determined to be in scope for the SiFive X280 IP
- The X280 is a high-end application processor with broad CWE applicability across categories

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

Detailed Workflow for each CWE

Security Requirements Creation

Distill each CWE into a specific requirement for the X280. Perform a deep review of the CWE, identify data or interfaces relevant to the CWE, and write Security Requirements that tie the CWE to the design

Rule Template Creation

Map the Security Requirements into RTL signals for the IP. Assess the flow/no-flow requirements and any exceptions. Create Radix rules to be executed.

Test Creation

Identify existing C tests that exercise the functionality in question. If a test does not exist, create a new one.

Rule Execution and Analysis

Execute the tests with the Radix rule enabled and assess the results. If a rule fails or does not evaluate correctly, refine the rule and re-run. If the rule continues to fail, assess the cause and document it.

Coverage Metrics Collection

When a rule passes, collect data to support assurance evidence including coverage data and other data artifacts (e.g. log files, etc.). When a rule fails, it indicates the CWE weakness exists. Provide documentation explaining why.

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

Example RISC-V Templates for CWE-1262

Radix Rule template for CWE-1262

```
// CWE-1262
// Contains 2 rules

// Below is a description of each of the macros in the rules.
// These macros should be set to the signals specific to the design being analyzed.

// REG1:        This is the register asset being tracked for confidentiality
// DATA_OUTPUT: The signal that REG1's information should never flow to
// IGNORES1:    The signals that REG1's information can legally flow to

// REG2:        This is the register asset being tracked for integrity
// DATA_INPUT:  The signals whose information should not flow into REG2
// IGNORES2:    The signals that DATA_INPUT information can legally flow to
// CONDITION1,
// CONDITION2:   The signals which when valid track the flow of information in DATA_INPUT

// MACROS as defined for SiFive's X280 RISC-V Processor
@define REG1 unused
@define DATA_OUTPUT  unused
@define CONDITION1   unused
@define CONDITION2   unused
@define IGNORES1     unused

@define REG2 mem.csr_wdata_latched
@define DATA_INPUT mem_axi_wdata
@define IGNORES2 unused
@define CONDITION3 mem_axi_awaddr === 'h00010018
@define CONDITION4 mem_axi_wvalid === 'b1

// Integrity Rule: Information from data input, when valid signals are asserted, shall not flow to REG2 out
//                 ignoring encrypted outputs.
NO_WRITE_REG2_INTEG: assert iflow(
    @{DATA_INPUT} when @{CONDITION3} && @{CONDITION4}
    =/=>
    @{REG2}
);
```

Generalizes required RTL signals to construct rule

Provides Rule template for easy of porting to other RISC-V

C test Template for CWE-1262 any RISC-V

```c
#include <stdio.h>
#include <stdint.h>
#include <string.h>
#include "firmware.h"

#define BASE      0x00010000  // base address
#define REG1      0x00000018  // offset for REG1
#define REG2      0x00000018  // offset for REG2

/*
 * Main
 */

int main(int argc, char *argv[]) {

    volatile uint32_t* reg1_ptr = (uint32_t*)(BASE + REG1);
    volatile uint32_t* reg2_ptr  = (uint32_t*)(BASE + REG2);

print_str("Write/Read Test \n");

/*
 * for i n 0 to 7
 * perform a 4 byte (32 bit word)  write at the base address for BASE + REG1 + 4*i
 * perform a 4 byte (32 bit word) read from the base address for BASE + REG2 + 4*i
*/

    for (int i = 0; i < 8; i++) {
        // Write a 32-bit value
        reg1_ptr[i] = 0xDEADBEEF;

        // Read a 32-bit value
        uint32_t value = reg2_ptr[i];
        print_str("CWE 1262 Test\n");
    }

    return 0;
}
```

User need only set memory map for registers

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

Results Summary (to date)

- To date, **16/59** of the CWEs in scope for SiFive's X280 IP have been completed.

- **12 pass**, **3 fail**, 1 out of scope
  - Failures were not design bugs but intentional behaviors implemented by design (details next slide)

- **Passing:** The supporting security properties for the CWE are passing and appropriate coverage has been collected to support assurance.
- **Failing:** At least 1 of the supporting security properties for the CWE are failing. Does not necessarily indicate a vulnerability, only that the CWE as written is violated
- **Not in Scope:** Explicitly labeled as out of scope for the IP.

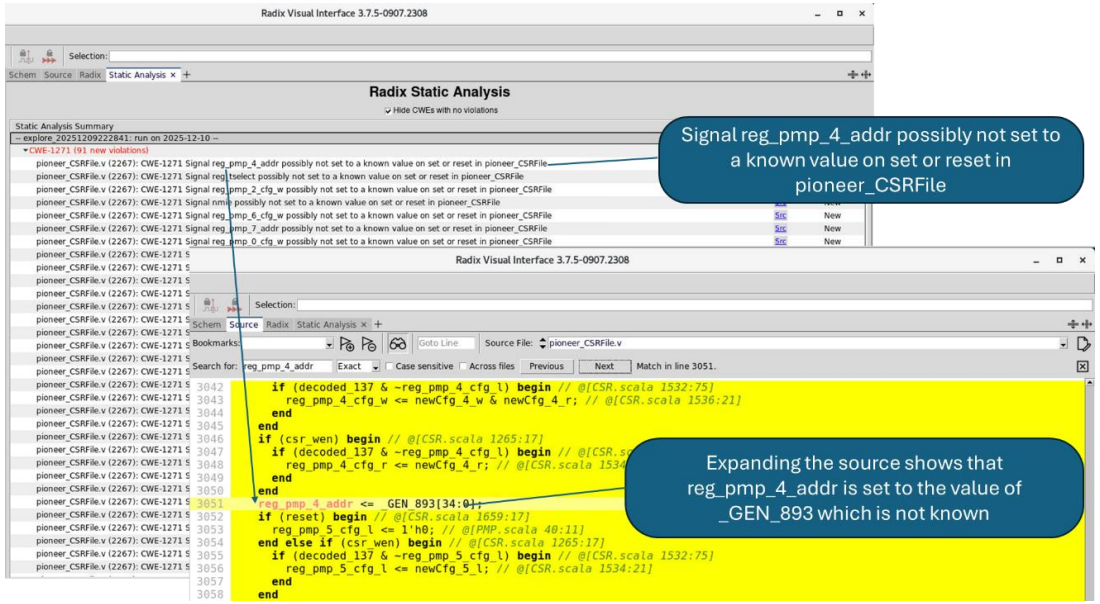
CWE	Pass/Fail
CWE-1262	Passing
CWE-1271	Failing
CWE-1258	Failing
CWE-1299	Passing
CWE-1260	Passing
CWE-1268	Passing
CWE-1264	Passing
CWE-1280	Passing
CWE-1251	Not in Scope
CWE-1257	Passing
CWE-1242	Passing
CWE-203	Passing
CWE-1220	Passing
CWE-1222	Failing
CWE-1059	Passing
CWE-1053	Passing

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

CWE Violations: CWE-1271

CWE-1271: Uninitialized Value on Reset for Registers Holding Security Settings

- Focuses on ensuring that security-critical logic is set to a known state on reset.
- If logic is not set to a known state, there is a window during which the device may be in an insecure state and vulnerable to attack.
- Team identified set of security critical registers within the X280 processor.
- Radix-ST (static analysis) determined whether any of the registers were not properly reset.
- 9 of the 15 registers violate the CWE. Upon review, these registers were found to be benign for BAE's use case.



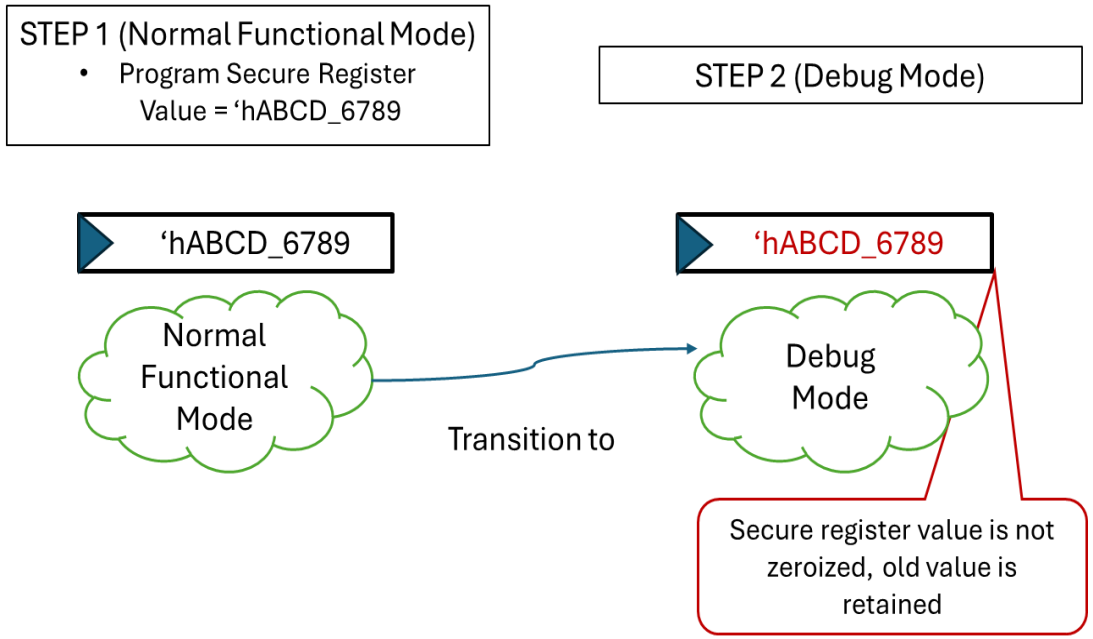
CWE-1271 Radix-ST showing registers not being reset

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

CWE Violations: CWE-1258

CWE-1258: Exposure of Sensitive System Information Due to Uncleared Debug Information

- Focuses on ensuring that security sensitive registers are cleared when switching into debug mode.
- Identified a set of security sensitive registers in the Hardware Cryptographic Accelerator (HCA) and the AES_KEY within it.
- After testing the AES_KEY is *not* zeroized when switching into debug mode and the rule **fails.**
- This is by design, and the X280 does not have the ability to broadly clear registers when switching into debug mode.
- This provided insight to BAE on how to address this at an SoC system-level



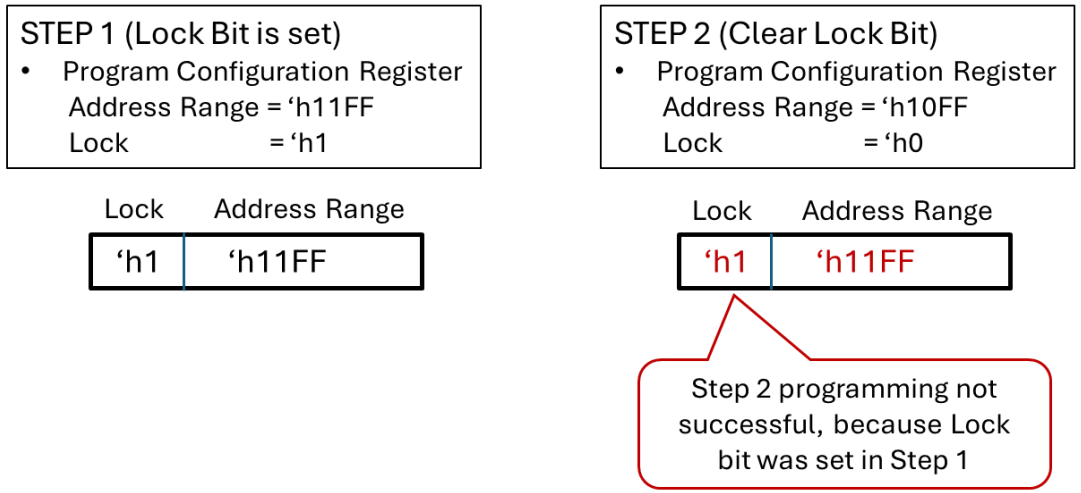
CWE-1258 - Data not cleared when switching into debug mode

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

CWE Violations: CWE-1222

CWE-1222: Insufficient Granularity of Address Regions Protected by Register Locks

- Focuses on the granularity of address regions that are protected by register locks
- In the X280, configuration bits to set and lock memory regions exist, but are not reconfigurable without a complete system reset.
- This is a design feature.
- A weakness remains such that firmware which modifies the memory protection via an upgrade or patch, would be unable to make these modifications without a complete system reset.



CWE-1222 - Register data not cleared after lock

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

Verification Methods for Each CWE

- Radix was used for the majority of CWEs
- However, for certain CWEs alternative methods were easier or Radix was not applicable

CWE	Radix Rule	Test Only	Other
CWE-1262	✓		
CWE-1271			✓ (Radix-ST)
CWE-1258	✓		
CWE-1299	✓		
CWE-1260	✓		
CWE-1268	✓		
CWE-1264	✓		
CWE-1280	✓		
CWE-1251			Not in Scope
CWE-1257			✓ (SVA)
CWE-1242		✓ (Chicken Bits)	
CWE-203	✓		
CWE-1220	✓		
CWE-1222		✓ (Lock Bit)	
CWE-1059			✓ (Manual)
CWE-1053			✓ (Manual)
TOTAL (16)	**9**	**2**	**5**

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

Challenges and Effort Estimations

- An initial estimation of the effort for each CWE was made to prioritize evaluation.
- Throughout the process, some were determined to be higher or lower effort.
- For ones identified as lower than expected, it was often because of reuse of the test case or Radix rule.

CWE	Effort Estimation	Actual Effort	Comment
CWE-1262	Medium	Low↓	Leveraged work done in Phase 1
CWE-1271	Medium	High ↑	6000+ violations in Radix-ST for the design. Focused on the CSR block to limit to 15 registers
CWE-1258	Medium	High ↑	Several iterations of the test-bench configurations
CWE-1299	Medium	Low↓	Leveraged work done for CWE-1262
CWE-1260	Medium	High ↑	Several iterations of the C program and the Radix rule were required
CWE-1268	Medium	Medium	Effort as expected
CWE-1264	Medium	High ↑	Several iterations of the C program and the Radix rule were required
CWE-1280	Medium	Medium	Effort as expected
CWE-1251	Medium	Low↓	Identified as out of scope for the X280
CWE-1257	Medium	Medium	SVA assertion written by BAE, no Radix rule
CWE-1242	Low	High ↑	BAE team had multiple iterations with SiFive
CWE-203	High	Low↓	Leveraged work done in Phase 1
CWE-1220	Medium	Medium	Leveraged work done for CWE-1222
CWE-1222	Medium	High ↑	Several iterations of the C program and the Radix rule were required
CWE-1059	Low	Low	Effort as expected
CWE-1053	Low	Low	Effort as expected

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

Summary and Next Steps

- A CWE-based methodology for RISC-V assurance was presented and demonstrated on SiFive's X280 IP for **16/59** CWEs in scope.

- Templates were created to ease portability to other RISC-V implementations.
  - We plan to make these templates publicly available

- Next steps are to complete the remaining CWEs in scope (all 59)

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659

QUESTIONS?

DISTRIBUTION STATEMENT A. Approved for public release: distribution is unlimited. Approval ID: 26-T-0659